

The background of the image features a dark blue gradient on the left, transitioning into a large, vibrant, abstract shape on the right. This shape is composed of overlapping curved segments in shades of orange, pink, and purple, creating a dynamic, modern aesthetic.

AWS re:Invent

NOV. 27 – DEC. 1, 2023 | LAS VEGAS, NV

SEC218 - R

Best practices for setting up AWS Organizations policies

Nivedita Tripathi

Sr. Product Manager
AWS

Liam Wadman

Sr. Solutions Architect
AWS

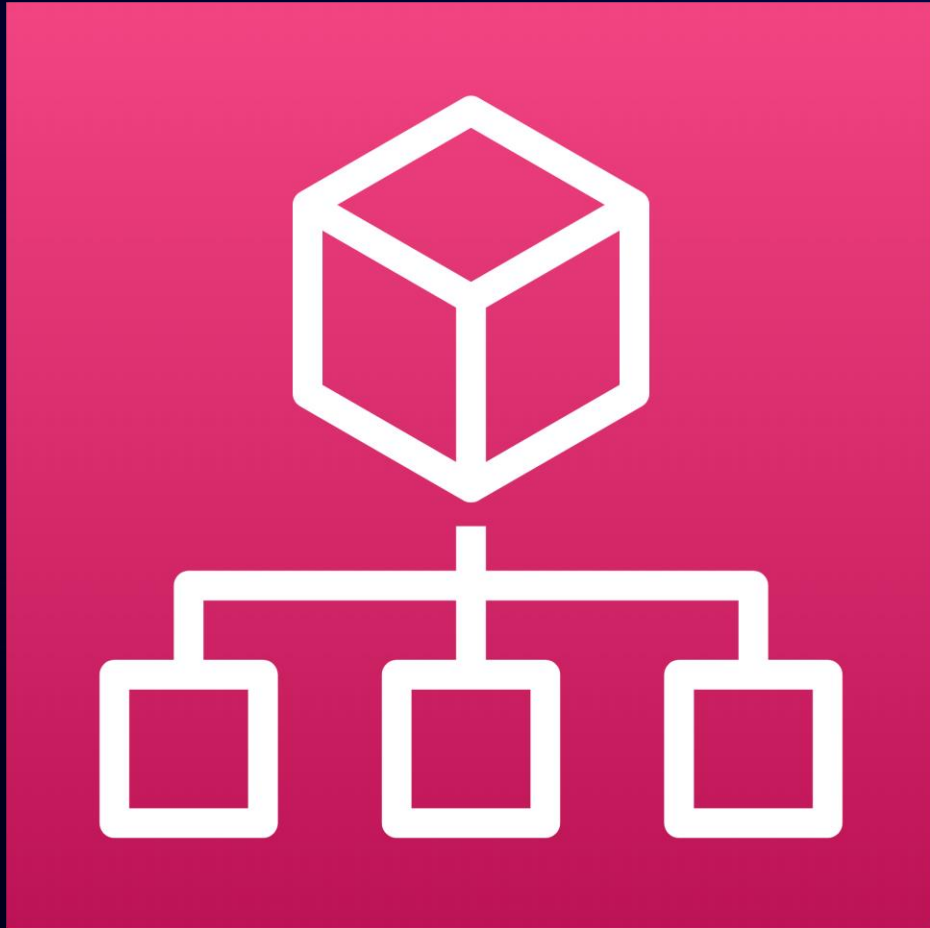


Agenda

- 01 What is AWS Organizations service?
- 02 Why to consider AWS Organizations?
- 03 AWS Organizations Policy Types
- 04 Management Policies
- 05 Authorization Policy (Service Control Policy)
- 06 Recap
- 07 Q&A

What is AWS Organizations?

Provides you tools to centrally govern and manage your cloud environment



Create and Manage AWS accounts

Customize your environment by applying policies

Centralize all billing

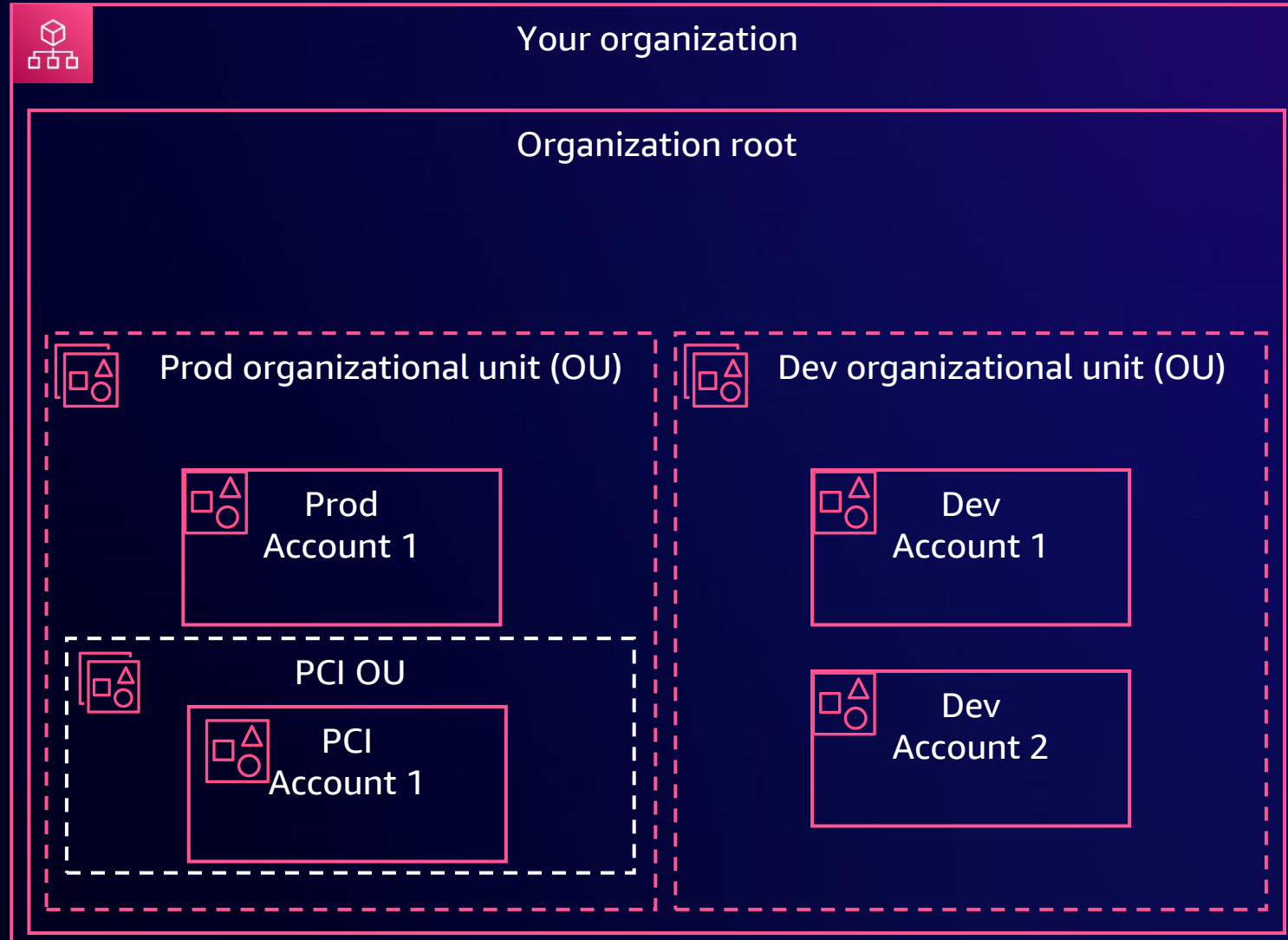
Integrate with many AWS services

Available at no additional cost

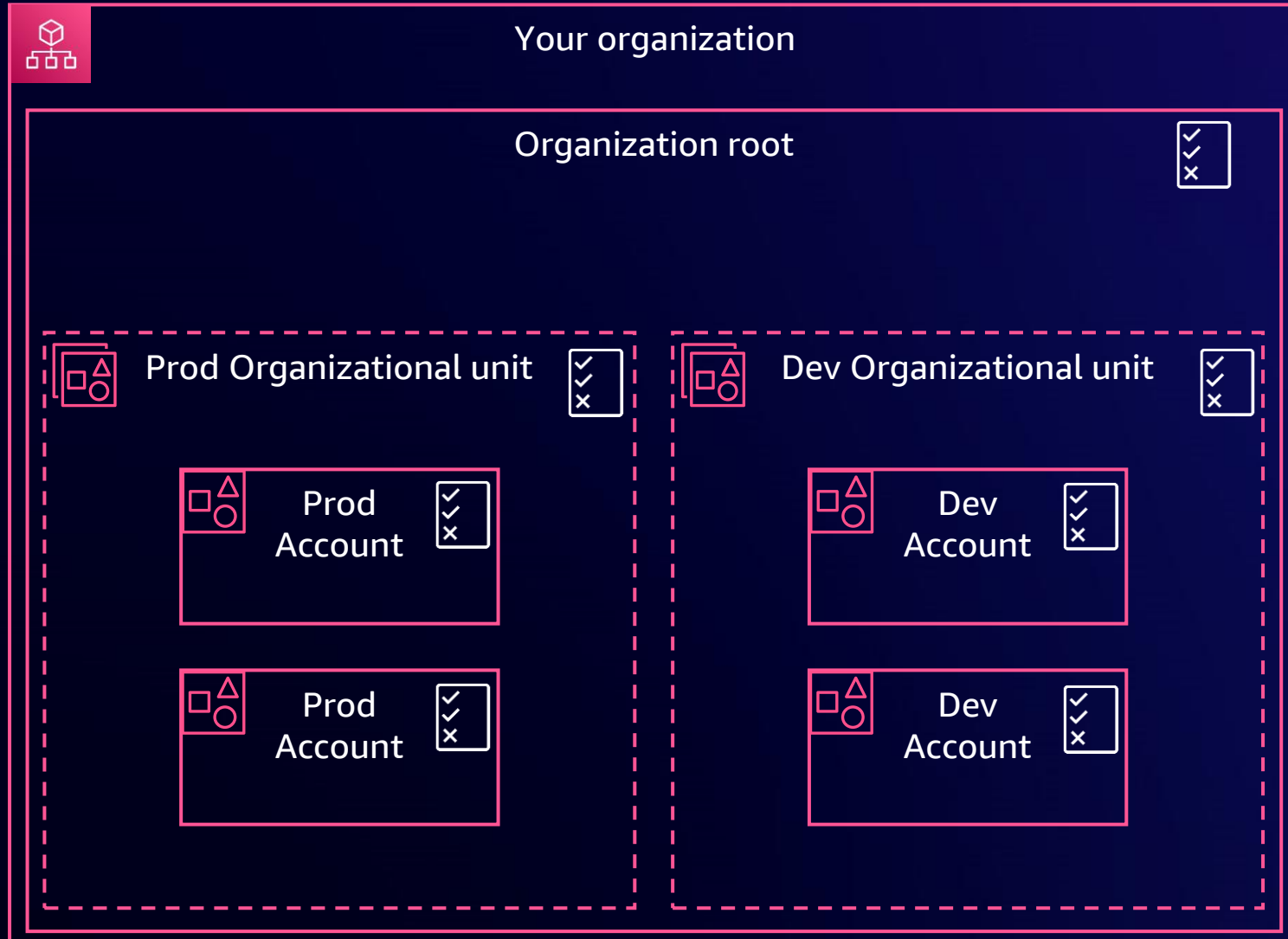


Getting started with
AWS Organizations

Organizations structure and member AWS accounts



Manage account behavior with Organizations policies

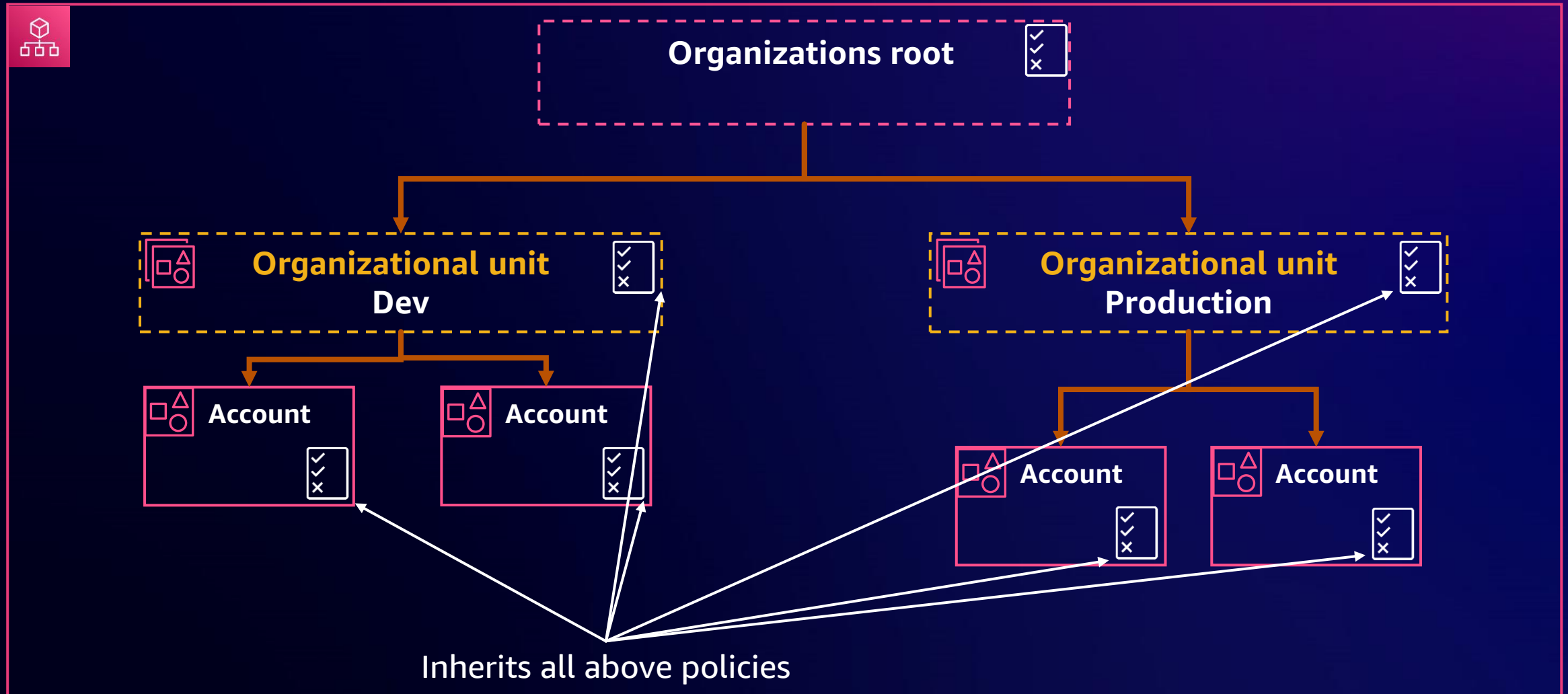


Organization Policies

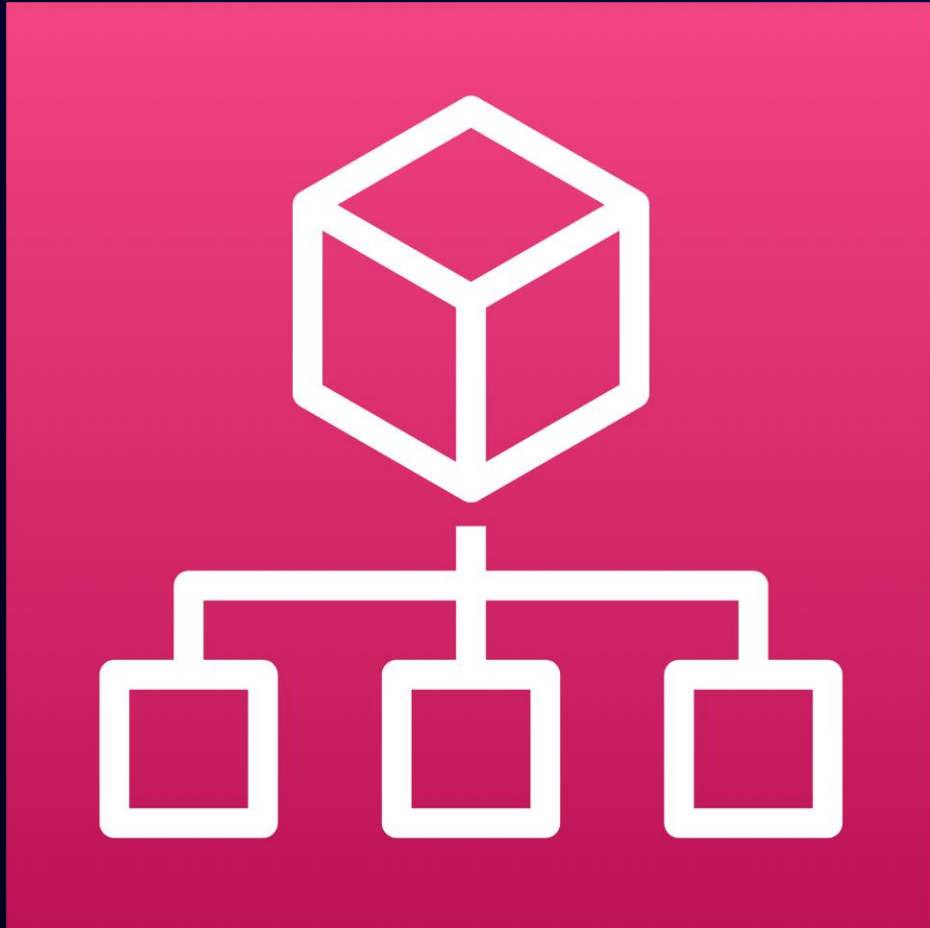
Policies Attach to the your whole organization(root), OUs, or individual accounts

 = Policy Attachment Point

Inheritance with Organizations policies



Best practices for AWS Organizations



Use **many accounts**

Structure your AWS Organizations for ease of management – **Not like your org chart**

Don't run workloads **in the management account**

Protect the **management account email**

Multi Account Strategy Whitepaper



AWS Organizations policy types



Service control policy



Tag policy



Backup policy



AI Opt-out policy

Authorization policy

Management policies

AWS Backup



AWS Backup

Centrally manage and
automate data protection



Amazon RDS



Amazon EBS



Amazon EFS



Amazon EC2



AWS Storage
Gateway



Amazon DynamoDB



Amazon FSx
for Lustre



Amazon FSx for
Windows File Server



Amazon Aurora

Backup policies



Backup policy



Backup policy



Backup plan

Backup rules



- Frequency
- Maintenance window
- AWS Region
- Backup vault
- Tags

Best practices for applying a backup policy



Backup policy

- Decide on a **backup strategy**
- **Start small** and iterate over time
- Consider **other AWS Regions and accounts**
- Limit the **number of rules** per policy



Scan me

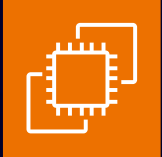
Tag policies



Tag policy

- Standardization of tags
- Enforce tagging compliance
- Manage compliance through AWS resource groups
- Attach up to 10 tag policies per attach point

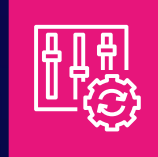
Tag policy supports



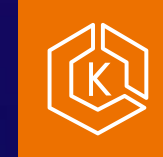
Amazon Elastic Compute
Cloud (Amazon EC2)



AWS Lambda



AWS Config



Amazon Elastic Kubernetes
Service (Amazon EKS)



AWS Network Firewall



Amazon Relational Database
Service (Amazon RDS)



Amazon DynamoDB



Amazon Connect



Amazon Athena



Amazon GuardDuty



AWS Backup



Tag policy

And more to come!

Best practices for applying a tag policy



Tag policy

- Determine a **tagging strategy**
- **Start small** by creating a simple tag policy
- **Educate** account administrators
- **Use caution** in enforcing compliance



Tag policy

Tag policy example

Service Control Policy (SCP)

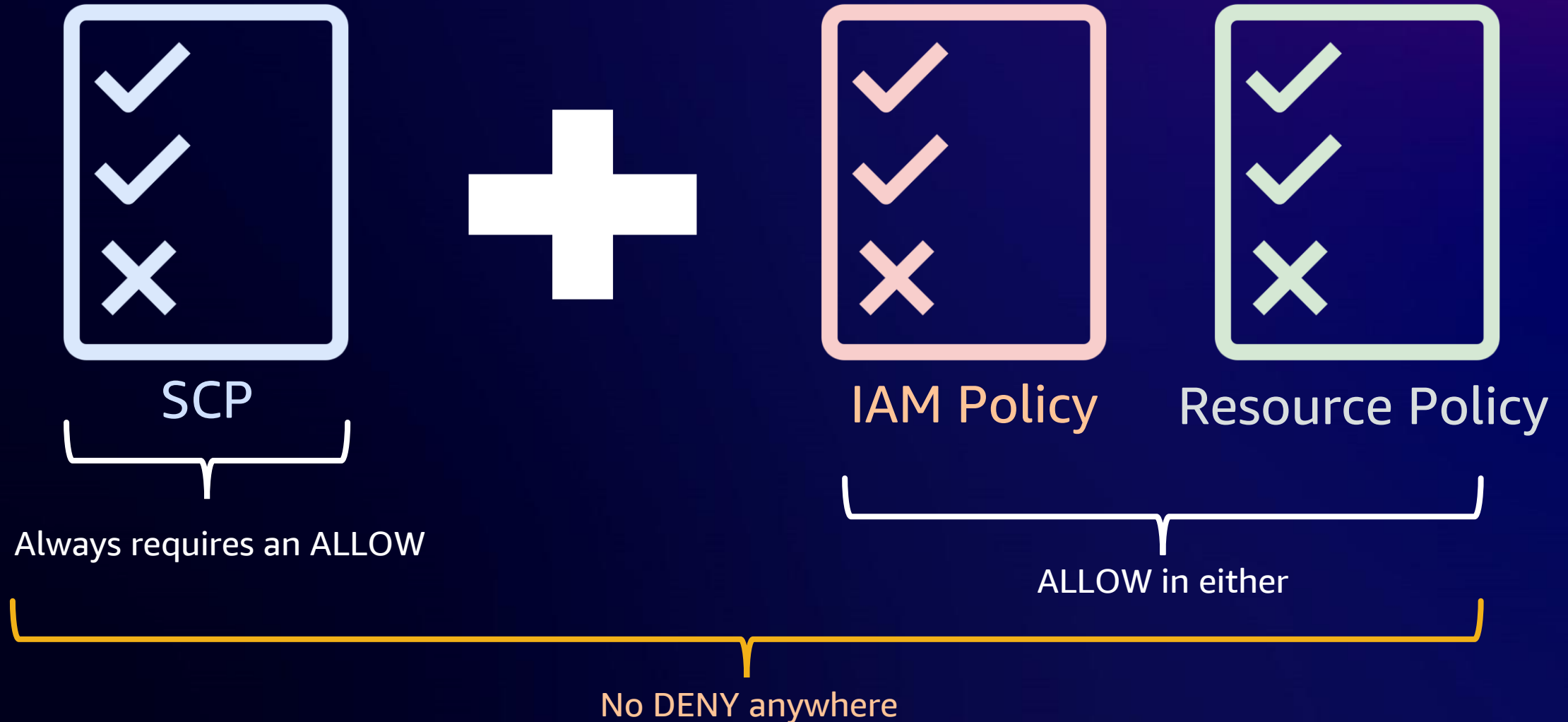
Sets the maximum allowable permissions in an AWS Organizations, OU, or Account



- Attaches to Organizations, OUs, or Accounts. **5 SCPs per attach point**
- Apply to all **IAM Roles, IAM Users, and the root users** in **organization member accounts**
- Same syntax as IAM policy
- Applies to **all IAM authorization decisions** in an AWS account

How SCPs work with AWS Authorization

SCP's act as a guardrail for access in your organization



Best practices for applying SCPs



Test in a non-production environment

Allow list approved AWS services

Deny list undesirable actions

Use OUs to maximize policy space

Apply iteratively, over time

Example SCP: Allow only specified Regions

```
"Effect": "Deny",
"Action": [
  "*",
  ...
],
"Resource": "*",
"Condition" : {
  "StringNotEquals": {
    "aws:RequestedRegion" : [
      "us-east-1",
      "eu-central-1"
    ]
  }
}
```

Policy highlights

Use **aws:RequestedRegion** condition key to specify allowed Regions with **StringNotEquals** operator

Example SCP: Prevent usage of the root user

```
"Effect": "Deny",  
"Action": "*",  
"Resource": "*",  
"Condition": {  
  "StringLike": {  
    "aws:PrincipalArn": [  
      "arn:aws:iam::*:root"  
    ]  
  }  
}
```

Policy highlights

Deny all actions by the root user in member accounts

Use **aws:PrincipalArn** condition key for root user with wildcard ("*****") for account-id

Create process for temporary exceptions using the **aws:PrincipalAccount** condition key

Protect your critical data from deletion

```
{  
  "Effect": "Deny",  
  "Action":  
  [  
    "s3:DeleteObject",  
    "ec2:DeleteSnapshot"  
  ],  
  "Resource": "*"   
}
```

Policy highlights

Deny specific resource deletion **actions**

Example SCP: Prevent leaving the organization

```
{  
  "version": "2012-10-17",  
  "statement": [  
    {  
      "effect": "Deny",  
      "action": [  
        "organizations:LeaveOrganization"  
      ],  
      "resource": "*"   
    }  
  ]  
}
```

Policy Highlights

When an account leaves your organization, your SCPs and other integrations no longer apply

Prevent disabling security services

```
{  
  "version": "2012-10-17",  
  "statement": [  
    {  
      "effect": "Deny",  
      "action": [  
        "cloudtrail:StopLogging",  
        "guardduty:StopMonitoring*"  
      ],  
      "resource": "*"   
    }  
  ]  
}
```

Attackers may try to disable security services to cover their tracks – stop them!

Bonus best practice: Start with our examples



Recap

- 01 What is AWS Organizations?
- 02 Why consider AWS Organizations?
- 03 AWS Organizations policy types
- 04 Management policies
- 05 Authorization policy (service control policy)
- 06 Recap and Q&A

Next steps



Getting started with
AWS Organizations



Multi-account Strategy
Whitepaper



Backup policy example



Service control policy
examples

Save the date for AWS re:Inforce

JUNE 10 - 12, 2024 | PHILADELPHIA, PA



AWS
re:Inforce



© 2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Thank you!



Please complete the session survey in the mobile app

Nivedita Tripathi

✉ nivtrips@amazon.com

Liam Wadman

✉ liwadman@amazon.com

